

LLMs USAGE POLICY [AI]

Version 0.0

Document name	LLMs USAGE POLICY [AI]
Computer engineer	Name
Date	YYYY-MM-DD
Version	v 0.0
Confidentiality	[CONFIDENTIALITY LEVEL]



1. EXECUTIVE SUMMARY

This document defines the LLMs Usage Policy of **[COMPANY NAME]**. The policy establishes a governance model for integrating enterprise LLMs solutions while ensuring productivity, security, regulatory compliance, and operational control. Alternative solutions may also be admitted, provided that they comply with the requirements set out in this document for business use.

The policy applies to employees, consultants, human resources, and third parties acting on behalf of **[COMPANY NAME]**.

This document has been drafted in accordance with Zero Trust principles, data minimization and anonymization, human-in-the-loop safeguards, and the assessment of enterprise solutions with compliant contractual and operational guarantees (e.g., no-training, auditability, retention, logging, and administrative controls). **[COMPANY NAME]** may also rely on productivity, collaboration, and security suites already adopted internally.

INDEX

LLMs USAGE POLICY [AI]Version X.Y 1

1. EXECUTIVE SUMMARY2

2. ZTA & DATA ANONYMIZATION4

2.1 Operative Anonymization.....4

3. GOVERNANCE6

3.1 AI Steering Committee (Operational Governance)6

3.2 Data Classification.....6

4. HUMAN-IN-THE-LOOP7

5. AI PROVIDER SCREENING.....7

5.1 Periodic review and compliance8

5.2 Compliance alignment8

5.3 Exclusion Criteria9

6. NON-PREFERRED ALTERNATIVES (COMPLIANT).....10

7. STATE OF THE ART OF LLMs.....12

8. COMPLIANCE / STANDARDS / REGULATORY REFERENCES12

8.1 HREF15

9. OPEN SOURCE / OPEN CONTENT LICENSE.....16

9.1 COPYRIGHT NOTICE.....16

9.2 DISTRIBUTION LICENSE (CC BY-SA 4.0).....16

9.3 REDISTRIBUTION AND SHARING OBLIGATIONS.....16

9.4 CANONICAL REPOSITORY AND VERSIONING16

9.5 CONTRIBUTIONS AND OPERATIONS ON BEHALF OF THE RIGHTS HOLDER.....17

9.6 ORIGINALITY AND LICENSING REPRESENTATION17

9.7 NEUTRALITY, LICENSING, VENDOR-AGNOSTIC APPROACH17

9.8 SPECIAL REPOSITORY-SPECIFIC AUTHORIZATION RECORD.....17

9.9 PURPOSE AND SCOPE.....18

2. ZTA & DATA ANONYMIZATION

[COMPANY NAME] applies Zero Trust principles (NIST SP 800-207): no implicit trust; continuous authentication and authorization; least privilege; telemetry and per-session policy enforcement [HREF-01], together with other security postures consistent with enterprise AI usage.

In summary, the following shall be remembered:

- **Anonymize and pseudonymize** personal data and confidential information before using LLMs.
 - Avoid entering secrets (passwords, tokens, keys), credentials, sensitive configurations, or non-public vulnerability details; hardcoding in the codebase is prohibited.
 - Avoid entering hot code or IP; if necessary, minimize context and use redaction or placeholders.
- **Verify LLM outputs:** they must never be accepted uncritically or without validation; pay special attention to citations and URLs [HREF-12].
- **Compartmentalize dev/test/prod environments;** enforce role-based and session-based access control; adopt least-privilege approaches (IAM, RBAC/ABAC), endpoint protection, and flow sandboxing.
- **Logging, monitoring, and audit:** track access, prompts, outputs, and data flow while respecting privacy and minimization; retention must align with internal policy.
- **Supply chain:** assess components (SDKs, plug-ins, connectors, models) and updates; apply controls consistent with SSDF/NIST and recognized best practices.

ZTA principles do not apply only at the point of LLM use; they apply to the entire production workflow and all involved environments (dev/test/prod, CI/CD, workstation, identity, network, cloud, logging), because otherwise the same ZTA principles would be undermined.

2.1 Operative Anonymization

Anonymization is an operational control, not merely a principle, and it must be applied before sending or processing any non-public information through a web-based LLM. **The following steps are preliminary and must be supplemented as needed across the full lifecycle** (dev/test/prod) and in any environment used (workstation, CI/CD, cloud, collaboration).

- **Data classification:** Public / Internal / Confidential / Highly Confidential.
- **Anonymity:** remove direct identifiers (names, email addresses, customer numbers, work-order codes, internal IPs/hostnames, private URLs, etc.).
 - Replace identifiers with consistent placeholders (e.g., CUSTOMER_A, USER_1, SERVER_X), preserving only the semantics that are strictly necessary.
 - Generalize values (month/year; ranges for amounts; generic locations; etc.) whenever the specific detail is not indispensable.
 - Minimize context: use sanitized excerpts and avoid complete dumps (logs, configurations, repositories).
 - For attachments: prefer excerpts and avoid full uploads of documents containing non-public data.

- Keep the placeholder-to-real-value mapping only in authorized internal systems; never in the prompt.
 - Final check: no secrets, keys, or tokens; no clear-text personal data; no hot code; no unnecessary customer data.
-

3. GOVERNANCE

Governance defines responsibilities, controls, and training for a consistent, reviewable, and auditable use of AI, aligned with NIST AI RMF and related frameworks [HREF-02].

3.1 AI Steering Committee (Operational Governance)

[COMPANY NAME] relies on an **AI Steering Committee** for governance responsibilities, oversight, and continuous improvement of this policy. The committee acts as the decision-making body for approvals, reviews, and exception management relating to AI tools, providers, and workflows, as well as for coordinating ongoing AI literacy updates.

It is represented by the following technical and managerial positions: Policy Owner (X), Delivery Owner (Y), Sec & IT Ops, HR, Function Managers (Z1, Z2).

- **Cadence:** consultations ad necessitatem; extraordinary consultation within 3 business days in the event of incidents or significant regulatory changes; extendable up to one month for the onboarding of new providers or capabilities.
- **Quorum:** the presence of the Policy Owner, the Delivery Owner, and **at least** one designated technical reference is required; otherwise, any deliberation shall not be considered effective or executable.
- **Scope:** policy review; approval of justified exceptions; validation of upgrade plans; review of incidents, audits, and KPIs; and related matters.
- **Exception assessment:** every exception must be documented (reason, risk impact, duration, data processed, mitigations, owner, and deadline). The maximum duration of an exception shall be assessed ad necessitatem.

3.2 Data Classification

Operational classes:

- **Public:** information intended for external disclosure (or already public) that may be disclosed without significant risk to [COMPANY NAME], customers, or third parties. [FIPS impact: LOW].
- **Internal:** non-public information whose access is limited to personnel of [COMPANY NAME] (and, where applicable, authorized third parties). Unauthorized disclosure would cause limited but concrete impacts. [FIPS impact: MODERATE].
- **Confidential:** non-public information whose access is limited to personnel of [COMPANY NAME] (and, where applicable, authorized third parties). Unauthorized disclosure may cause moderate or material impacts, commercial harm, contractual breach, loss of competitive advantage, increased security risk, and regulatory non-compliance. [FIPS impact: MODERATE/HIGH].
- **Highly Confidential:** non-public information whose access is limited to personnel of [COMPANY NAME] (and, where applicable, authorized third parties). This includes strategic or sensitive data, hot code, critical artifacts, proprietary logic, critical pipelines, bid or tender materials, pricing plans, or any element the customer explicitly requires to be treated as restricted. Unauthorized disclosure may cause severe harm, penalties, significant reputational damage, and financial implications. [FIPS impact: HIGH].

The use of LLMs with data in any class other than Public always requires minimization and anonymization.

Any exception always requires approval and traceability.

SCOPE	POLICY OWNER	SEC & IT OPS	DELIVERY OWNER	FUNCTION MANAGERS	HR
Policy review	A/R	C	C	C	I
AI provider screening and reviews	A	R	C	I	C
DPIA/TIA for new services	C	C	A	C	C
Technical controls and compliance	A/R	C/R	C	I	C
Training and AI literacy	A/R	C	C	I	I
Incident handling (audit, regulation, compliance)	A/R	C/R	C	C	I

4. HUMAN-IN-THE-LOOP

LLMs are support tools, not autonomous reliable systems. Human supervision and validation are required for impact-bearing decisions and deliverables (legal, security, HR, finance, external communications, or high qualitative value).

NIST AI RMF frames the need for risk management and controls regarding reliability and transparency [HREF-02].

- Outputs delivered to customers: mandatory review and approval by the relevant function owner.
- For coding: mandatory code review, testing, security checks, and a prohibition on including secrets.
- Where a tool generates citations, links, or references, verify that they exist and are relevant (risk of fake citations) [HREF-12].

- Assess security issues related to supply chain compromise, data poisoning, unsafe tool use, prompt injection, and chain-of-custody failures.

5. AI PROVIDER SCREENING

[COMPANY NAME] adopts a risk-based and evidence-based screening process for AI providers. Minimum criteria include, by way of example: (a) verifiable no-training by default or opt-out; (b) retention and deletion controls; (c) enterprise controls (SSO/MFA, audit logs, admin); (d) transparency on sub-processors and data residency and geopolitical exposure (TIA, SCC; GDPR); (e) performance adequacy for the intended use case.

5.1 Periodic review and compliance

Provider selection is not static: [COMPANY NAME] maintains a periodic review of the whitelist based on benchmarks, security posture, incidents, contractual changes, and regulatory updates.

- **Periodic review:** semi-annual; potentially quarterly for critical or rapidly evolving providers.
- **Whitelist:** business use is allowed only for providers or solutions on the whitelist, unless formally approved exceptions apply.
- **DPA:** every whitelisted provider must have a Data Processing Agreement (DPA) in place. Where extra-EEA transfers exist, SCC/TIA and supplementary measures must be handled as required.
- **No data training:** controllable retention and deletion, audit logs, and enterprise controls (SSO/MFA/admin) are non-waivable minimum requirements for whitelist admission.

5.2 Compliance alignment

[COMPANY NAME] integrates compliance requirements and regulatory alignment into vendor screening and operational rules. Alignment must translate into verifiable requirements and evidence (training, controls, and vendor documentation).

- **EU AI Act Regulation (EU) 2024/1689:** It has the following operational timeline (European Commission): prohibited practices and AI literacy obligations applicable from 2 February 2025; governance and obligations for GPAI applicable from 2 August 2025; near-general applicability from 2 August 2026 (with further transition periods for some high-risk categories until 2 August 2027). [HREF-25]. It provides, among other things:
 - **AI literacy training:** Mandatory for all functions that use AI (target: HR, IT, Security, Legal, BU). Frequency: onboarding + annual refresh. Evidence: attendance register, training materials, learning assessments. Relevant prohibited practices: prohibition of uses that fall within prohibited practices (e.g. deceptive manipulation, social scoring; specific limitations in workplace/HR contexts). [HREF-25]
 - **Workplace/HR:** AI use in HR processes is considered sensitive; it requires additional controls, transparency, human review, and dedicated privacy assessment where necessary.
 - **GPAI provider management:** request documentation consistent with the role of user/deployer (no-training policy, data residency, sub-

processors, security measures, limitations, and usage instructions) and retain it as compliance evidence.

- **DORA Regulation (EU) 2022/2554:** For services aimed at customers in the financial sector or similar sectors, DORA has already been fully in force since 17 January 2025 and requires ICT resilience, third-party risk management, incident reporting, and testing. It requires the inclusion of business continuity, incident management, and controls over the AI provider, and therefore an appropriate control and monitoring framework. [HREF-27].
- **Cyber Resilience Act (CRA) Regulation (EU) 2024/2847:** Entered into force on 10 December 2024; vulnerability reporting and regulatory compliance obligations (and therefore also cybersecurity-oriented infrastructure and workflows compatible with reporting) apply from 11 September 2026; full infrastructure obligations of a SOC/SIEM-like nature apply from 11 December 2027. In particular:
 - Introduce mandatory cybersecurity requirements for products with digital elements (hardware, software, and related services).
 - Extend the security scope across the entire product lifecycle, from design to maintenance.
 - For products with digital elements and software/connectors/SDKs, require manufacturing and maintenance to take place in trusted, monitored, logged, and continuously audited environments, with secure-by-design postures and vulnerability handling.
 - **Vulnerability assessment:** introduce a formalized vulnerability-handling process with SAST/DAST, dependency scanning (SBOM where applicable), checks on AI components, CVE management, and remediation SLAs.
 - **(SIEM/SOC) Logging and traceability:** track versions (model, prompt template, connector), change management, and audit trail; retain vulnerability-handling and patching evidence.
- **NIS2 Directive (EU) 2022/2555:** National Italian transposition by 17 October 2024; it strengthens risk management and incident notification (early warning within 24 hours; notification within 72 hours). For in-scope services, the screening should take into account the provider's incident management and reporting. [HREF-26]

5.3 Exclusion Criteria

[COMPANY NAME] adopts evidence-based exclusion or suspension criteria for AI providers (regulatory sources, authority decisions, governmental reports, or documented cases), **not unproven assumptions or prejudice.**

1. Extra-EEA transfers (TIA, SCC);
2. Government access to data (geopolitical exposure);
3. Opacity regarding data residency and sub-processors;
4. Absence of enterprise controls (verifiable no-training, auditability, retention).

For providers processing or hosting data in high-risk jurisdictions, or subject to flexible legal obligations of governmental cooperation, [COMPANY NAME] must adopt supplementary measures (end-to-end encryption, internal key management, data minimization,

pseudonymization, and anonymization) in line with EDPB Recommendations 01/2020 [HREF-09].

Business use of providers that do not satisfy the requirements and parameters set out in this document shall be considered suspended until adequate and verifiable evidence becomes available.

In the absence of such conditions, the suspension shall be considered justified and documented in a traceable manner.

The following were also taken into account:

- Measures or suspensions imposed by European privacy authorities on AI services due to insufficient transparency and/or inadequate safeguards (e.g. decisions and investigations relating to the Chinese service DeepSeek in Italy). [HREF-14][HREF-15]
- Scrutiny and bans in government contexts on Chinese AI services due to data security and national security risks (e.g. measures in Australia, Belgium, and other countries). [HREF-16][HREF-17]
- The relevance of the Chinese regulatory framework (National Intelligence Law) in the risk analysis concerning government access and cooperation obligations. [HREF-10]
- National evidence/rules on data sovereignty and access by adversarial countries to sensitive systems (a principle applicable in VRM/third-party risk). [HREF-18]

PROVIDER	OFFERING	FLAGSHIP MODEL	BENCHMARK	PRIVACY/COMPLIANCE	OUTCOME
Microsoft	Productivity-suite copilots / enterprise AI	[MODEL / CAPABILITY]	[BENCHMARK / USE CASE]	Verify DPA, no-training, logging, MFA/SSO, retention	[OUTCOME / NOTES]
OpenAI	ChatGPT Enterprise / enterprise API	[MODEL / CAPABILITY]	[BENCHMARK / USE CASE]	Verify DPA, no-training, logging, MFA/SSO, retention	[OUTCOME / NOTES]
Anthropic	Claude Enterprise / API	[MODEL / CAPABILITY]	[BENCHMARK / USE CASE]	Verify DPA, no-training, logging, MFA/SSO, retention	[OUTCOME / NOTES]
Google	Gemini Workspace / Cloud	[MODEL / CAPABILITY]	[BENCHMARK / USE CASE]	Verify DPA, no-training, logging, MFA/SSO, retention	[OUTCOME / NOTES]
Other provider	[OFFERING]	[MODEL / CAPABILITY]	[BENCHMARK / USE CASE]	[PRIVACY / COMPLIANCE]	[OUTCOME / NOTES]

NB. Where geopolitical tensions, regulatory changes, or uncertainty affect continued compliance, **[COMPANY NAME]** may keep the evaluation of providers, internal deployments, or capabilities suspended until they are sufficiently documented.

6. NON-PREFERRED ALTERNATIVES (COMPLIANT)

Employees, consultants, and authorized third parties may adopt, **without pre-approval** unless otherwise specified, alternative tools or self-hosted open-source LLM deployments, provided that full compliance with this policy is always ensured.

- A plan with no-training enabled, in the case of web-based solutions, and clear retention and deletion conditions.
- Verifiable compliance and security requirements (DPA, audit, SSO/MFA, logging) and compatibility with VRM/DPIA/TIA where necessary.
- A Zero Trust posture: anonymization and minimization for any non-public data, as well as ZTA controls across the full production lifecycle, segmentation, and environment in the case of self-hosted deployments.

Failure to comply with the policy may trigger company measures (disciplinary or contractual) and may result in liability in the event of incidents.

7. STATE OF THE ART OF LLMs

Modern Large Language Models (LLMs) provide significant support for analysis, technical writing, summarization, code generation, and other professional activities. However, at the current state of the art they are not autonomous reliable systems: they produce probabilistic outputs, may hallucinate, and fail on tasks requiring verifiability, traceability, and decision continuity.

NIST AI RMF recommends managing AI risk across the full lifecycle, with particular attention to reliability, security, privacy, robustness, and transparency [HREF-02].

From a privacy and data-protection perspective, LLM usage may introduce specific risks (re-identification, prompt/output data leakage, excessive data collection, retention). Guidance and analyses on privacy risks in LLM systems highlight mitigation measures such as data minimization, privacy-by-design, access controls, and logging [HREF-19].

The adoption of LLMs and related integrations (RAG, agents, tool use) expands the attack surface: prompt injection, insecure output handling, supply-chain issues, data poisoning, model DoS, and risks linked to plug-ins or connectors. OWASP Top 10 for LLM Applications and MITRE ATLAS provide operational taxonomies for threat modeling and red teaming [HREF-20][HREF-21].

Independent analyses show that AI search systems may cite incorrect sources or fabricate references; accordingly, **[COMPANY NAME]** promotes human verification of sources and citations for deliverables and decisions of any impact level, in line with its quality standards [HREF-12].

The governing approach remains Human-in-the-Loop as a necessary control for security, compliance, legal, finance, customer deliverables, and other decisions. At present, LLMs remain powerful tools when used by a professional.

8. COMPLIANCE / STANDARDS / REGULATORY REFERENCES

FRAMEWORK	SCOPE	DETAIL	OUTPUT
EU AI Act 2024/1689	EU AI regulation	Obligations for GPAL, high-risk systems, transparency, and AI literacy.	AI inventory; compliance plan.
Cyber Resilience Act (EU 2024/2847)	Digital products	Security-by-design and vulnerability handling.	Patching SLA; disclosure.
NIST CSF 2.0	Cyber risk management	Reference standard (Govern, Identify, Protect, Detect, Respond, Recover).	Maturity and profiles; improvement plans.

NIST AI RMF 1.0	AI Risk	Govern–Map–Measure–Manage for AI risk.	AI risk register; controls; audit.
NIS2 (EU 2022/2555)	EU cyber resilience	Risk-management and incident-notification obligations.	Incident KPIs; reporting SLA; notification timeline.
DORA (EU 2022/2554)	Financial digital resilience	ICT risk management and third-party risk (where applicable).	Resilience tests; reporting.
ISO27001:2022 (ISMS)	Information security management system	Requirements to establish, maintain, and improve an ISMS.	Active ISMS; risk assessment; monitoring; remediation.
EDPB Rec. 01/2020	Data transfer	Supplementary measures for extra-EEA transfers (post Schrems II).	Documented TIA; technical and contractual measures.
NIST SP 800-53 Rev.5	Security & Privacy Controls	Catalog of controls for systems and organizations.	Control baseline; audit evidence.
NIST SP 800-171 Rev.2	Protection of CUI in non-federal environments	Security requirements for sensitive or controlled data.	Gap assessment; remediation plan.
NIST SP 800-207	Zero Trust	ZTA principles: no implicit trust; continuous verification; security by design.	ZTA controls on AI flows; retention; logging.
NIST SP 800-61	Incident Response	Guidelines for incident handling.	IR playbook; response times.
NIST SP 800-218 (SSDF)	Secure Software Development	Best practices for SDLC and software supply chain.	SDLC processes; SAST/DAST; SBOM.
NIST SP 800-30 / 800-37	Risk assessment / RMF	Methodologies for risk assessment and management.	Risk register; risk treatment.
ISO/IEC 42001:2023	AI Management System	Standard for AI governance (AIMS).	Implemented AIMS; periodic audits.

ISO/IEC 23894:2023	AI Risk Management	Guidelines for AI risk management.	AI risk assessment; controls.
ISO 31000	Enterprise Risk Mgmt	ERM principles and guidelines.	Risk governance; reporting.
ISO/IEC 27017 / 27018	Cloud security / PII	Cloud controls and personal-data protection in cloud environments.	Cloud control mapping; audit.
ISO/IEC 27002 / 27005	Security controls and risk management	ISMS controls and risk-management methodology.	Statement of Applicability; audit.
ISO/IEC 27701	Privacy Information Mgmt	Privacy extension to ISMS.	PIMS; DPIA; roles.
CSA CCM / STAR	Cloud control framework	Cloud Controls Matrix and STAR registries.	Cloud-control mapping; VRM.
GDPR (EU) 2016/679	Privacy	Principles and obligations for processing and transfers.	DPIA/controls; DPA, TIA, SCC.
MITRE ATLAS	AI threat landscape	Attack tactics and techniques against AI systems.	Red teaming; coverage.
OWASP Top 10 for LLM Apps	AI application security	Typical risks (prompt injection, supply chain, insecure output).	Threat model; mitigations; tests.
SOC 2 (AICPA)	Control assurance	Trust Services Criteria: security, availability, confidentiality, privacy.	SOC 2 report; gap remediation.

8.1 HREF

- [HREF-01] [NIST SP 800-207](#)
 - [HREF-02] [NIST AI RMF 1.0](#)
 - [HREF-03] [Provider enterprise privacy page]
 - [HREF-04] [Enterprise data-protection page for the productivity suite]
 - [HREF-05] [Provider A product / model page]
 - [HREF-06] [Provider B product / model page]
 - [HREF-07] [Provider C product / model page]
 - [HREF-08] [SWE-bench](#)
 - [HREF-09] [EDPB Recommendations 01/2020 on supplementary measures](#)
 - [HREF-10] [National Intelligence Law of the People's Republic of China](#)
 - [HREF-11] [Irish Data Protection Commission — TikTok fine and corrective measures](#)
 - [HREF-12] [Tow Center / Columbia Journalism Review — AI Search Has a Citation Problem](#)
 - [HREF-13] [California Attorney General — cease and desist letter to xAI](#)
 - [HREF-14] [Garante privacy — request for information to DeepSeek](#)
 - [HREF-15] [Garante privacy — DeepSeek blocked in Italy](#)
 - [HREF-16] [AP News — Australia bans DeepSeek on government devices](#)
 - [HREF-17] [Euractiv — Belgium bans DeepSeek from government devices](#)
 - [HREF-18] [U.S. DOJ — Final Rule on access to sensitive data by countries of concern](#)
 - [HREF-19] [EDPB — AI Privacy Risks & Mitigations: Large Language Models \(LLMs\)](#)
 - [HREF-20] [OWASP – Top 10 for Large Language Model Applications](#)
 - [HREF-21] [MITRE – ATLAS \(Adversarial Threat Landscape for AI Systems\)](#)
 - [HREF-23] [NIST SP 800-53 Rev.5](#)
 - [HREF-24] [ISO/IEC 42001:2023 \(AI management systems\)](#)
 - [HREF-25] [European Commission – AI Act timeline and application](#)
 - [HREF-26] [EUR-Lex – NIS2 Directive \(EU\) 2022/2555](#)
 - [HREF-27] [EUR-Lex – DORA Regulation \(EU\) 2022/2554](#)
 - [HREF-28] [EUR-Lex – Cyber Resilience Act Regulation \(EU\) 2024/2847](#)
-

9. OPEN SOURCE / OPEN CONTENT LICENSE

9.1 COPYRIGHT NOTICE

This document (the “Document”) and its contents are protected by copyright.

Creator and Rights Holder: N.F.

Copyright © [2026] N.F.

Unless otherwise stated, the Document is made available under the license specified in Section 1.2 below.

In any redistribution or adaptation of the Document, attribution to the Creator and Rights Holder must be preserved in a reasonable and readable form, in accordance with the applicable license terms.

Users are encouraged, but not required, to notify the Rights Holder of substantial changes made to the Document, including for record-keeping, comparison, or review purposes, using the contact details provided by the Rights Holder.

The Rights Holder, or a collaborator of the Rights Holder on this repository, may distribute or transmit the Document without physically attaching a copy of the license text, provided that the Document remains licensed under CC BY-SA 4.0 and the applicable attribution and license information are otherwise made available in a reasonable manner.

For the avoidance of doubt, any such distribution or transmission shall not limit, modify, revoke, or invalidate the application of CC BY-SA 4.0 to the Document.

9.2 DISTRIBUTION LICENSE (CC BY-SA 4.0)

This Document is released as open content under the **Creative Commons Attribution–ShareAlike 4.0 International License (CC BY-SA 4.0)**.

You are free to copy, redistribute, remix, transform, and build upon the Document, including for commercial purposes, provided that you comply with the terms of **CC BY-SA 4.0**.

A copy of the license, or a link to it, must accompany any redistribution.

License URL: <https://creativecommons.org/licenses/by-sa/4.0/>

9.3 REDISTRIBUTION AND SHARING OBLIGATIONS

Any redistribution of the Document, whether in its original or modified form, must preserve, in full and in readable form where applicable, the following:

- A) the copyright and license notices;
- B) attribution to the Creator as set out in Section 1.1;
- C) an indication of whether modifications have been made;
- D) a reference or link to the CC BY-SA 4.0 license;
- E) in the event of adaptation or modification, distribution of the adapted material under CC BY-SA 4.0, consistently with the ShareAlike requirement;
- F) no additional legal or technical restrictions that would prevent others from exercising the rights granted by the license.

9.4 CANONICAL REPOSITORY AND VERSIONING

The canonical version of the Document, including its history, changelog, tags, and releases, may be maintained in this GitHub repository (the “Canonical Repository”).

Each published version should include, where applicable:

- A) a unique identifier (such as a tag);
- B) the publication date; and
- C) a version number.

For the avoidance of doubt, this section describes repository management and publication practices only, and does not limit any rights granted under CC BY-SA 4.0.

9.5 CONTRIBUTIONS AND OPERATIONS ON BEHALF OF THE RIGHTS HOLDER

CC BY-SA 4.0 governs rights of use and reuse, as well as attribution and ShareAlike obligations. Any operational or organizational requirements (including approval workflows, official publication channels, and consolidation in the Canonical Repository) are intended as governance rules and/or contractual obligations for persons acting on behalf of the Rights Holder, and do not constitute additional conditions of the public license.

Subject to CC BY-SA 4.0, employees, consultants, contractors, and third parties who draft or modify the Document in the course of activities carried out on behalf of the Rights Holder shall be required to:

- A) submit changes through a merge request / pull request to the Canonical Repository, where used, or through the contact channel indicated by the Rights Holder;
- B) include a clear description of the changes and the reasons for them;
- C) comply with the defined editorial and versioning standards;
- D) refrain from presenting forks as the internal or external reference version without synchronization, unless expressly approved by the Rights Holder.

9.6 ORIGINALITY AND LICENSING REPRESENTATION

For each contribution submitted to the Canonical Repository, the contributor represents that, to the best of their knowledge:

- A) the contribution is original, or may otherwise be lawfully used and contributed;
- B) the contributor has the right to submit and license it;
- C) the contribution may be released under CC BY-SA 4.0, consistently with the license governing the Document.

Where applicable, contributions made by persons acting on behalf of the Rights Holder shall be deemed made in accordance with any applicable contractual arrangements between those persons and the Rights Holder, without prejudice to the public licensing of the Document under CC BY-SA 4.0.

Any contribution implies acceptance of this representation.

9.7 NEUTRALITY, LICENSING, VENDOR-AGNOSTIC APPROACH

This license applies to the logical design of the Document, its structure, graphics, and contents, to the extent protected by applicable law.

Any references in the Document to users, providers, tools, platforms, or specific organizational contexts are merely descriptive and do not alter the open-content nature of the Document or the rights and obligations established by CC BY-SA 4.0.

The design and overall logic of this Document are intended to remain independent of any commercial arrangement with providers and are expressly designed to be vendor-agnostic.

9.8 SPECIAL REPOSITORY-SPECIFIC AUTHORIZATION RECORD

Where the Rights Holder, or a collaborator of the Rights Holder on this repository, grants a specific repository-related authorization by separate certified communication, the persons or entities concerned may be listed in a file named `.authorized_without` in this repository. Such record is intended solely for administrative, evidentiary, or organizational purposes.

If such file does not exist, no special repository-specific authorization under this Section 1.8 shall be deemed recorded or granted.

For the avoidance of doubt, the absence of such file, or the absence of any specific entry in it, shall not limit, modify, revoke, or invalidate the application of CC BY-SA 4.0 to the Document.

9.9 PURPOSE AND SCOPE

As reflected in this licensing and notice section, the purpose is to support a professional workflow for drafting, compliance, and enterprise-grade use of LLMs, while ensuring the broadest possible reuse, adaptation, and dissemination of the Document under CC BY-SA 4.0.

END OF DOCUMENT